



## Ασφάλεια Δικτύων

---

### Εργαστηριακή Άσκηση 3 Snort 2024-2025

Ονοματεπώνυμο:

Κεχριώτη Ελένη

ΑΜ:

3210078

IP: 172.16.1.44

IP Συναδέλφου: 172.16.1.55

#### Άσκηση

1) Για να ανιχνεύσουμε ping από το υπολογιστή του συναδέλφου με TTL ίσο με 99 θα χρησιμοποιήσουμε τον παρακάτω κανόνα:

```
alert icmp 172.16.1.55 any -> 172.16.1.44 any (msg:"ICMP Ping with TTL 99"; ttl:99; sid:100001; rev:1;)
```

Όπου:

**alert icmp:** Καθορίζει ότι πρόκειται για κανόνα ειδοποίησης που αφορά το πρωτόκολλο ICMP. Το ICMP χρησιμοποιείται όταν κάνουμε ping.

**172.16.1.55 any -> 172.16.1.44 any:** Καθορίζει ότι πρόκειται για πακέτο από την IP 172.16.1.55 από οποιαδήποτε θύρα, προς την IP 172.16.1.44 προς οποιαδήποτε θύρα.

**msg:"ICMP Ping with TTL 99":** Ορίζει το μήνυμα που θα εμφανιστεί στην ειδοποίηση όταν ενεργοποιηθεί ο κανόνας.

**ttl:99:** Καθορίζει ότι το πακέτο πρέπει να έχει TTL ίσο με 99.

**sid:100001; rev:1:** Χρησιμοποιούνται για την εσωτερική διαχείριση των κανόνων στο Snort, με sid να είναι ο μοναδικός κωδικός του κανόνα και rid είναι το revision id του κανόνα.

Όταν ενεργοποιηθεί ο κανόνας, το Snort θα καταγράψει μια ειδοποίηση που θα αναφέρει ότι εντοπίστηκε ένα πακέτο ICMP με TTL 99 από την IP του συναδέλφου. Το TTL είναι ένα πεδίο στο κεφάλι του IP πακέτου που υποδεικνύει τον μέγιστο αριθμό routers που μπορεί να διασχίσει ένα πακέτο πριν απορριφθεί. Η τυπική τιμή TTL είναι συνήθως 64 ή 128. Μια τιμή TTL 99 μπορεί να θεωρηθεί ασυνήθιστη και να υποδηλώνει μια σάρωση δικτύου ή άλλη ανώμαλη δραστηριότητα.

Πράγματι, όπως φαίνεται παρακάτω, το snort εντόπισε το ping που εκτελέστηκε και εμφάνισε το μήνυμα που περιμέναμε. Από αριστερά προς τα δεξιά φαίνεται η ημερομηνία και ώρα που διεξήγει, ο κωδικός του κανόνα, το μήνυμα που είπαμε να εμφανίζει ο κανόνας, η προτεραιότητα του κανόνα (default είναι 0, αν θέλαμε μπορούσαμε να δώσουμε μεγαλύτερη προτεραιότητα αλλά αυτό δεν ήταν απαραίτητο εδώ), το πρωτόκολλο του πακέτου και οι IPs του αποστολέα και παραλήπτη.

```
Preprocessor Object: SF_DCEPC2 Version 1.0 <build 3>
Commencing packet processing (pid=3932)
01/15-18:57:50.385274  [**] [1:100001:1] ICMP Ping with TTL 99 [**] [Priority: 0] {ICMP} 172.16.1.55 -> 172.16.1.44
01/15-18:57:51.394330  [**] [1:100001:1] ICMP Ping with TTL 99 [**] [Priority: 0] {ICMP} 172.16.1.55 -> 172.16.1.44
01/15-18:57:52.404643  [**] [1:100001:1] ICMP Ping with TTL 99 [**] [Priority: 0] {ICMP} 172.16.1.55 -> 172.16.1.44
01/15-18:57:53.420250  [**] [1:100001:1] ICMP Ping with TTL 99 [**] [Priority: 0] {ICMP} 172.16.1.55 -> 172.16.1.44
```

2) Για να ανιχνεύσουμε σύνδεση στον υπολογιστή μας μέσω RDP θα χρησιμοποιήσουμε τον παρακάτω κανόνα:

```
alert tcp 172.16.1.55 any -> 172.16.1.44 3389 (msg:"RDP Connection Attempt"; flags:S; sid:100002; rev:1;)
```

Όπου:

**alert tcp:** Καθορίζει ότι πρόκειται για κανόνα ειδοποίησης που αφορά το πρωτόκολλο TCP. Το TCP χρησιμοποιείται από το RDP για τη δημιουργία μιας σταθερής σύνδεσης μεταξύ δύο συστημάτων.

**172.16.1.55 any -> 172.16.1.44 3389:** Όπως και προηγουμένως. Το μόνο που αλλάζει εδώ είναι ότι καθορίσαμε ως θύρα προορισμού την 3389 γιατί είναι η τυπική θύρα που χρησιμοποιείται για το RDP.

**flags:S:** Δεν είναι απαραίτητο να το χρησιμοποιήσουμε. Ωστόσο, η προσθήκη της σημαίας **S** περιορίζει τον κανόνα σε πακέτα που ξεκινούν μια νέα TCP σύνδεση (SYN flag). Αυτό είναι πιο συγκεκριμένο και μειώνει τις πιθανότητες ψευδών συναγερμών.

Για τα υπόλοιπα σημεία του κανόνα η αιτιολόγηση είναι ίδια με προηγουμένως. Το μόνο που αλλάζει και αξίζει να σημειωθεί είναι το sid το οποίο θα παρατηρήσετε είναι sid+1, καθώς χρειάζεται να είναι μοναδικό και η σειριακή ανάθεση τους είναι πιο εύκολη για την κατανόηση και εκσφαλμάτωση τους.

Όταν ενεργοποιηθεί ο κανόνας, το Snort θα καταγράψει μια ειδοποίηση κάθε φορά που λάβει ένα πακέτο που ταιριάζει με την περιγραφή του κανόνα. Ο κανόνας είναι πιο συγκεκριμένος και θα ενεργοποιηθεί μόνο όταν υπάρχει μια προσπάθεια σύνδεσης από τον υπολογιστή του συναδέλφου προς τον υπολογιστή μας.

Όπως φαίνεται στο screenshot παρακάτω ο κανόνας αυτός λειτούργησε όπως θα περιμέναμε, και εμφάνισε την ειδοποίηση όταν επιχειρήθηκε σύνδεση.

```
01/15-19:06:42.394526  [**] [1:100002:1] RDP Connection Attempt [**] [Priority: 0] {TCP} 172.16.1.55:10834 -> 172.16.1.44:3389
```

3) Για να ανιχνεύσουμε nmap Fast Scan προς τον υπολογιστή μας θα χρησιμοποιήσουμε τον παρακάτω κανόνα

```
alert tcp 172.16.1.55 any -> 172.16.1.44 21 (flags:S; msg:"Nmap Fast Scan Detected"; sid:100003; rev:1;)
```

Όπου:

**alert tcp:** Καθορίζει ότι πρόκειται για κανόνα ειδοποίησης που αφορά το πρωτόκολλο TCP. Το TCP είναι το πρωτόκολλο που χρησιμοποιεί κυρίως το Nmap για να στέλνει πακέτα SYN σε διάφορες θύρες προκειμένου να εντοπίσει ανοιχτές υπηρεσίες.

**flags:S:** Χρησιμοποιείται για τον ίδιο λόγο με προηγουμένως. Το Nmap Fast Scan στέλνει κυρώς TCP Syn πακέτα.

**172.16.1.55 any -> 172.16.1.44 21:** Το Nmap Fast Scan σκανάρει τις 100 πιο γνωστές θύρες για κάθε πρωτόκολλο. Τα πρωτόκολλα http, https, ssh χρησιμοποιούν τις θύρες 80, 443 και 22, οπότε δεν θέλουμε να μας εμφανιστεί ειδοποίηση για σύνδεση σε αυτές τις θύρες. Η θύρα 21 είναι πολύ γνωστή και χρησιμοποιείται από το πρωτόκολλο ftp. Το Nmap Fast Scan σκανάρει την συγκεκριμένη για να εντοπίσει αν είναι ανοιχτή, είναι κοινός στόχος για τυπικά scans. Οπότε, μπορούμε στον κανόνα να χρησιμοποιήσουμε αποκλειστικά αυτή, για να μειώσουμε το αριθμό των ειδοποιήσεων που θα μας έρθουν.

Το snort ελέγχει κάθε πακέτο που έρχεται αν ταιριάζει με τον συγκεκριμένο κανόνα, και αν ναι, τότε εμφανίζει την ειδοποίηση. Αν δεν είχαμε περιορίσει τον κανόνα αυτόν τότε θα μας εμφανιζόντουσαν πάρα πολλές ειδοποιήσεις λόγω των πακέτων που στέλνει το Fast Scan. Γενικά θεωρείται καλύτερη πρακτική να εξειδικεύουμε τους κανόνες και να μην λαμβάνουμε αχρείαστα πολλές ειδοποιήσεις.

Πράγματι, σε Fast Scan, ο κανόνας ενεργοποιήθηκε και εμφανίστηκε ειδοποίηση όπως φαίνεται παρακάτω.

```
01/15-19:07:22.009166  [**] [1:100003:1] Nmap Fast Scan Detected [**] [Priority: 0] {TCP} 172.16.1.55:52480 -> 172.16.1.44:21
```

Εναλλακτικά θα μπορούσαμε να χρησιμοποιήσουμε τον κανόνα

```
alert tcp 172.16.1.55 any -> 172.16.1.44 !80,!443,!22 (flags:S; msg:"Nmap Fast Scan Detected"; sid:100003; rev:1;)
```

ο οποίος ενεργοποιείται για κάθε πακέτο που λαμβάνεται σε οποιαδήποτε θύρα, αγνοώντας απλά τις θύρες 80,443, και 22. Η διαφορά εδώ θα ήταν, όπως ειπώθηκε και παραπάνω, ότι θα εμφανιζόντουσαν πολλές περισσότερες ειδοποιήσεις.

4) Για να ανιχνεύσουμε Nmap Fin Scan στον υπολογιστή μας, θα χρησιμοποιήσουμε τον παρακάτω κανόνα

```
alert tcp 172.16.1.55 any -> 172.16.1.44 22 (flags:F; msg: "Nmap FIN Scan Detected";  
sid:100004; rev:1;)
```

Όπου:

**alert tcp 172.16.1.55 any -> 172.16.1.44 22:** Καθορίζει ότι πρόκειται για κανόνα ειδοποίησης που αφορά το πρωτόκολλο TCP που προέρχονται από τη διεύθυνση IP 172.16.1.55 προς τη διεύθυνση IP 172.16.1.44 στη θύρα 22 (SSH).

**flags:F:** Το flag **F** αντιστοιχεί στο flag FIN σε ένα πακέτο TCP. Οι σάρωσεις τύπου FIN στέλνουν πακέτα με το flag FIN για να προσδιορίσουν αν μια θύρα είναι ανοιχτή.

Όταν κάποιος εκτελέσει Nmap Fin Scan προς τον υπολογιστή μας στη θύρα 22, τότε θα ενεργοποιηθεί ο κανόνας και το Snort θα εμφανίσει ειδοποίηση. Η θύρα 22 είναι συνήθως ανοιχτή για την υπηρεσία SSH (Secure Shell), η οποία επιτρέπει απομακρυσμένες συνδέσεις σε ένα σύστημα. Οπότε είναι ένας συνηθισμένος στόχος για τους επιτιθέμενους και ένας μπορεί να χρησιμοποιήσει ένα FIN scan για να ελέγξει γρήγορα αν η θύρα 22 είναι ανοιχτή ή κλειστή. Το Fin Scan χρησιμοποιείται συνήθως για να μειωθεί ο "θόρυβος" στο δίκτυο. Είναι πιο διακριτικό scan και συνήθως "κρύβεται" μέσα σε κανονική κυκλοφορία. Ακόμα, μπορεί να παρακάμψει συστήματα ανίχνευσης εισβολέων (IDS/IPS), καθώς συνήθως να είναι ρυθμισμένα να αναζητούν μόνο για SYN scans.

Ο κανόνας λειτούργησε όπως περιμέναμε και όταν εκτελέστηκε Nmap Fin Scan εμφάνισε την παρακάτω ειδοποίηση.

```
01/15-19:07:42.988400  [**] [1:100004:1] Nmap FIN Scan Detected [**] [Priority: 0] {TCP} 172.16.1.55:49025 -> 172.16.1.44:22
```

Παρακάτω, φαίνονται συνολικά όλες οι ειδοποιήσεις που εμφάνισε το snort κατά την διάρκεια της εργαστηριακής εξέτασης.

Σημείωση: Το Ping εκτελέστηκε 2 φορές.

```
Commencing packet processing (pid=3932)  
01/15-18:57:50.385274  [**] [1:100001:1] ICMP Ping with TTL 99 [**] [Priority: 0] {ICMP} 172.16.1.55 -> 172.16.1.44  
01/15-18:57:51.394330  [**] [1:100001:1] ICMP Ping with TTL 99 [**] [Priority: 0] {ICMP} 172.16.1.55 -> 172.16.1.44  
01/15-18:57:52.404643  [**] [1:100001:1] ICMP Ping with TTL 99 [**] [Priority: 0] {ICMP} 172.16.1.55 -> 172.16.1.44  
01/15-18:57:53.420250  [**] [1:100001:1] ICMP Ping with TTL 99 [**] [Priority: 0] {ICMP} 172.16.1.55 -> 172.16.1.44  
01/15-19:06:20.412724  [**] [1:100001:1] ICMP Ping with TTL 99 [**] [Priority: 0] {ICMP} 172.16.1.55 -> 172.16.1.44  
01/15-19:06:21.425663  [**] [1:100001:1] ICMP Ping with TTL 99 [**] [Priority: 0] {ICMP} 172.16.1.55 -> 172.16.1.44  
01/15-19:06:22.445686  [**] [1:100001:1] ICMP Ping with TTL 99 [**] [Priority: 0] {ICMP} 172.16.1.55 -> 172.16.1.44  
01/15-19:06:23.460462  [**] [1:100001:1] ICMP Ping with TTL 99 [**] [Priority: 0] {ICMP} 172.16.1.55 -> 172.16.1.44  
01/15-19:06:42.394526  [**] [1:100002:1] RDP Connection Attempt [**] [Priority: 0] {TCP} 172.16.1.55:10834 -> 172.16.1.44:3389  
01/15-19:07:22.008309  [**] [1:100002:1] RDP Connection Attempt [**] [Priority: 0] {TCP} 172.16.1.55:52480 -> 172.16.1.44:3389  
01/15-19:07:22.009166  [**] [1:100003:1] Nmap Fast Scan Detected [**] [Priority: 0] {TCP} 172.16.1.55:52480 -> 172.16.1.44:21  
01/15-19:07:42.988400  [**] [1:100004:1] Nmap FIN Scan Detected [**] [Priority: 0] {TCP} 172.16.1.55:49025 -> 172.16.1.44:22
```